

Программный комплекс обучения методам обнаружения, анализа и устранения последствий компьютерных атак «Ampire». Лабораторная работа № 1.

**СЦЕНАРИЙ № 5 «ЗАЩИТА НАУЧНО-ТЕХНИЧЕСКОЙ ИНФОРМАЦИИ
ПРЕДПРИЯТИЯ»**

Садова Диана Алексеевна, Диденко Дмитрий Владимирович, А6

Содержание

1	Описание сценария	6
2	Перечень уязвимостей и последствий	8
2.1	Уязвимость 1. Слабый пароль пользователя.	8
2.2	Последствие. Developer backdoor.	12
2.3	Уязвимость 2. XSS (CVE-2019-17427).	16
2.4	Последствие. Redmine User.	22
2.5	Уязвимость 3. Blind SQL (CVE-2019-18890).	24
3	Мониторинг	29
3.1	Анализ событий ViPNet IDS NS	29
3.2	Регистрация инцидентов	33
4	Вывод	38

Список иллюстраций

1.1	Описание сценария	7
2.1	Сброс пароля	9
2.2	Сброс пароля	9
2.3	Переходим на удаленный рабочий стол	10
2.4	Окно Active Directory Users and Computers	11
2.5	Изменяем пароль	12
2.6	Запуск исполняемого файла в планировщике	13
2.7	Путь до исполняемого файла	13
2.8	Переходим на удаленный рабочий стол	14
2.9	Открыть Task Scheduler	14
2.10	Удаляем Evil task	15
2.11	Удаляем svchosting.exe	15
2.12	последствие «Dev backdoor» устранённо	15
2.13	Пример добавления кода, выводящего на экран надпись XSS в wiki-страницу	16
2.14	При нажатии на поле wiki-страницы запускается код	16
2.15	Данный код включает REST API при выполнении с учетной записи admin	17
2.16	Содержимое файла redcloth3.rb	17
2.17	Изменения в файле redcloth3.rb Код, исправляющий уязвимость CVE-2019-17427	18
2.18	Исправление в файле redcloth3.rb	18
2.19	Успешное устранение уязвимости	19
2.20	Подключение к серверу Redmine	19
2.21	Файл redcloth3.rb	20
2.22	Файл redcloth3.rb отредактированный	21
2.23	Перезапускаем службу	21
2.24	Успешное устранение уязвимости	21
2.25	Список пользователей Redmine	22
2.26	Удаление пользователя hacker	22
2.27	Находим пользователя hacker	23
2.28	Удаляем hacker	23
2.29	Последствие Redmine User устранено	24
2.30	При отправке запроса SLEEP(2) время ожидания ответа возрастает до 4 секунд, что свидетельствует об инъекции	24

2.31	Нарушитель посимвольно перебирает содержимое конфиденциального проекта	25
2.32	Содержимое файла query.rb с исправлением уязвимости	26
2.33	Файл query.rb	27
2.34	Исправляем query.rb	27
2.35	Перезапускаем службу	28
2.36	Переходим на web страницу	28
2.37	Успешное устранение уязвимости	28
3.1	Панель фильтрации событий в ViPNet IDS NS	30
3.2	Список событий класса network-scan за период наблюдения	31
3.3	Карточка события с полным текстом сработавшего правила	32
3.4	События сканирования RDP-порта узла 10.10.4.11 с внешнего адреса	32
3.5	События обращения к SMB-ресурсам файлового сервера (порт 445)	33
3.6	События класса web-application-attack, зафиксированные на веб-сервере Redmine	33
3.7	Карточка инцидента «Атака на Manager Workstation 1 на базе Developer»	34
3.8	Карточка инцидента «Атака на Developer на базе Kali»	35
3.9	Карточка инцидента «Атака на веб-сервер redmine.ampire.corp с попыткой эксплуатации уязвимости SQL-инъекции»	36
3.10	Карточка инцидента «Атака Blind SQL-инъекция на сервере Redmine»	37

Список таблиц

1 Описание сценария

Последовательность действий нарушителя следующая:

- 1) Внутренний нарушитель подбирает пароль на файловый сервер и меняет существующий на сервере файл другим файлом с backdoor (дефектом алгоритма).
- 2) Пользователь Dev-1 загружает и запускает файл с backdoor.
- 3) Внутренний нарушитель получает контроль над компьютером пользователя Dev-1 и загружает скрипт для похищения учетных данных из браузера. Запускает данный скрипт и получает логин - пароль к Redmine.
- 4) Внутренний нарушитель проводит атаку stored XSS для включения на Redmine сервере REST API. Вредоносный код записывается на Wiki-страницу проекта Dev1. Получив доступ к консоли администратора, внутренний нарушитель создает нового пользователя Redmine с правами администратора.
- 5) Внутренний нарушитель ожидает, когда администратор просмотрит страницу с внедренным вредоносным кодом.
- 6) Внутренний нарушитель проводит Blind SQL-инъекцию, получает доступ к данным конфиденциального проекта.

Ниже представлена логическая схема сценария № 5 «Защита научно-технической информации предприятия», красными стрелками обозначены

вредоносные действия нарушителя, а зелеными - легитимные действия любого пользователя (рис. 1.1).

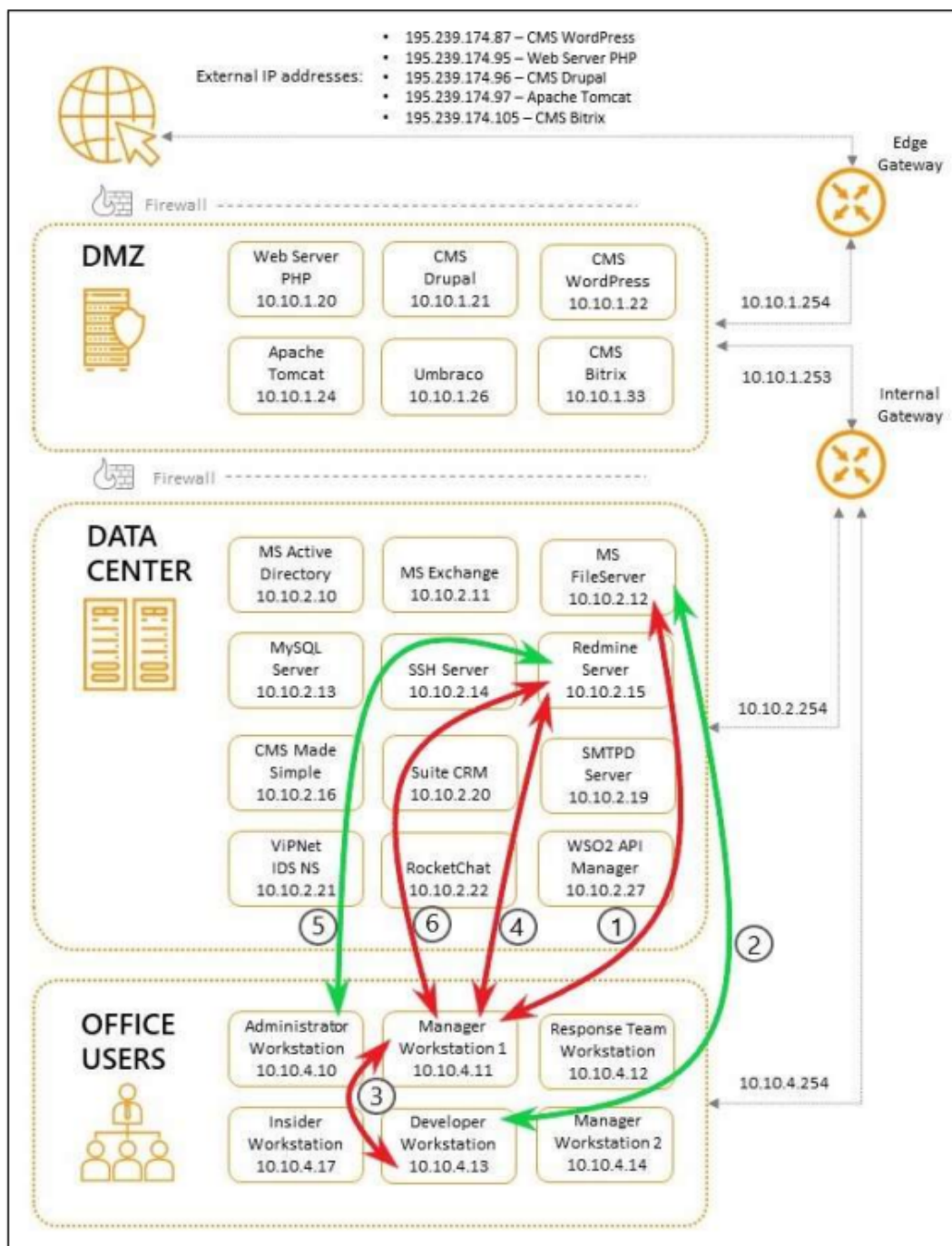


Рис. 1.1: Описание сценария

2 Перечень уязвимостей и последствий

Для сценария № 5 «Защита научно-технической информации предприятия» определены три уязвимости и два последствия:

- 1) Уязвимость 1. Слабый пароль пользователя.
- 2) Последствие. Developer backdoor.
- 3) Уязвимость 2. XSS (CVE-2019-17427).
- 4) Последствие. Redmine User.
- 5) Уязвимость 3. Blind SQL (CVE-2019-18890).

2.1 Уязвимость 1. Слабый пароль пользователя.

На файловом сервере установлен слабый пароль для входа, что позволяет нарушителю перебрать данный пароль со словарем. После успешной авторизации на файловом сервере нарушитель загружает .bat файл и получает доступ к учетным данным пользователя dev1.

Решение: для закрытия уязвимости необходимо изменить пароль на более сложный, не содержащийся в словаре. Для изменения пароля на сервере AD открыть «Active Directory Users and Computers», найти пользователя dev1, нажать на «Reset Password» (Рисунок 2) и ввести новый пароль.(рис. 2.1).

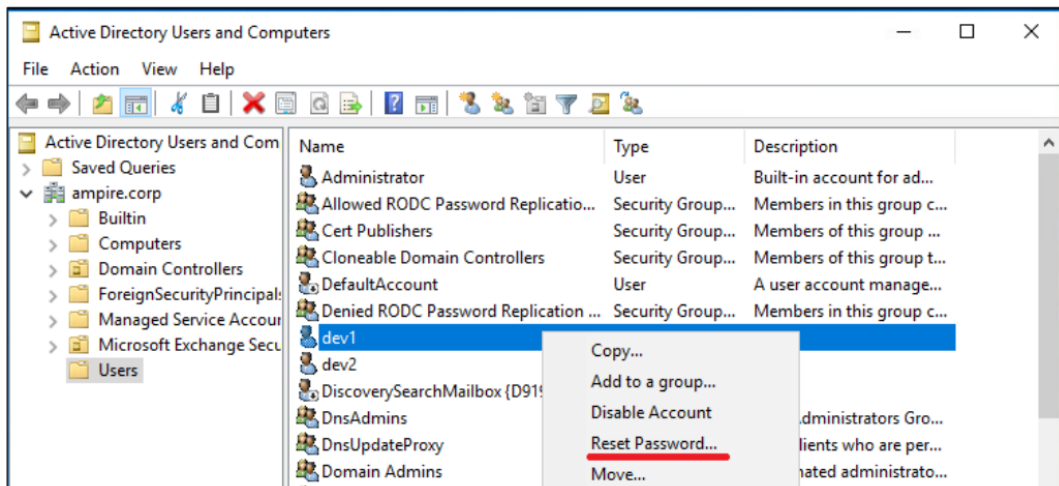


Рис. 2.1: Сброс пароля

После изменения пароля пользователя dev1 уязвимость успешно устранена.(рис. 2.2).

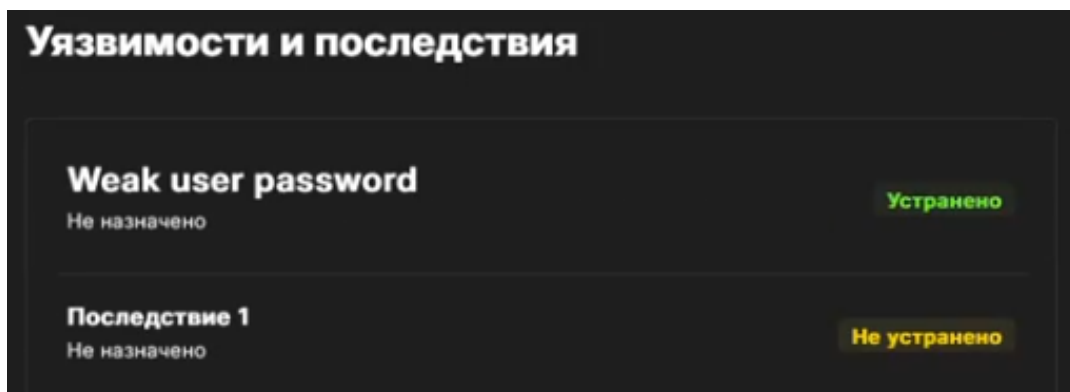


Рис. 2.2: Сброс пароля

Что было сделано:

- 1) Переходим на удаленный рабочий стол для измененя пароля пользователя «10.10.2.10 - Remote Desktop Connection» (рис. 2.3).

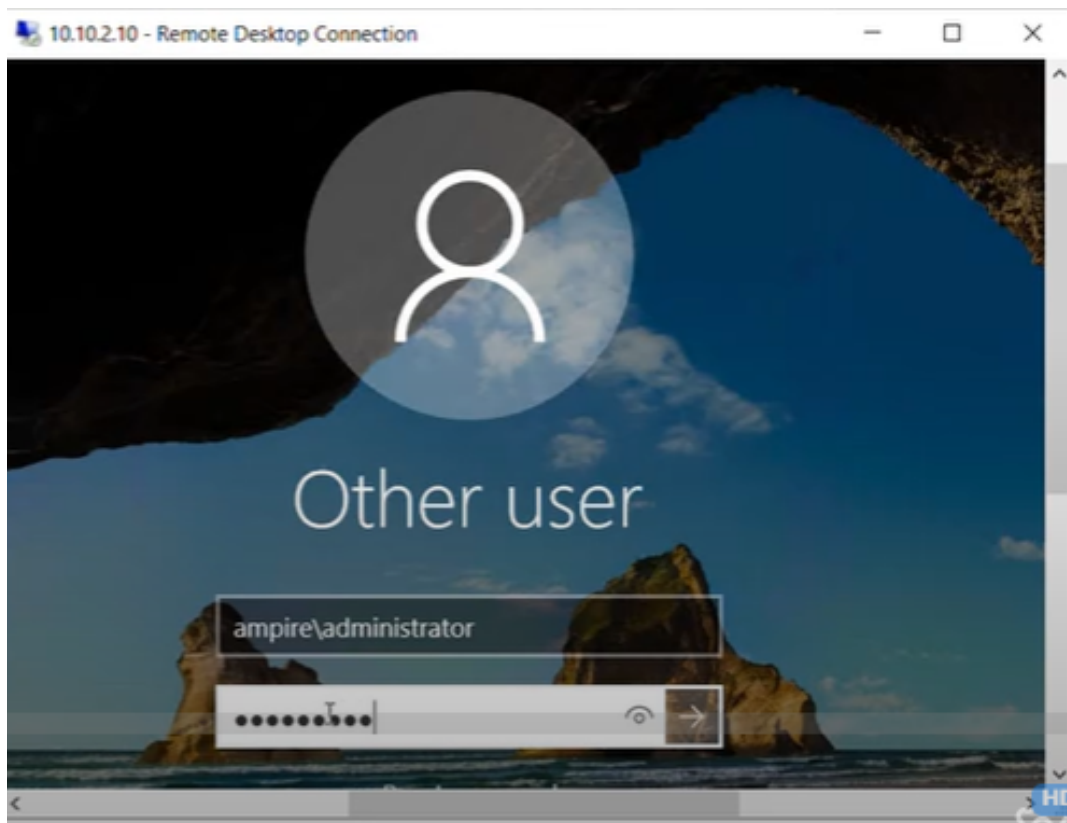


Рис. 2.3: Переходим на удаленный рабочий стол

- 2) Окно Active Directory Users and Computers развёрнуто дерево `ampire.corp` -> Users; в списке - Administrator, Allowed RODC Password Replication, Cert Publishers, CloneableDomainControllers, DefaultAccount, dev1, dev2, DiscoverySearchMailbox, DnsAdmins и т.д.(рис. 2.4).

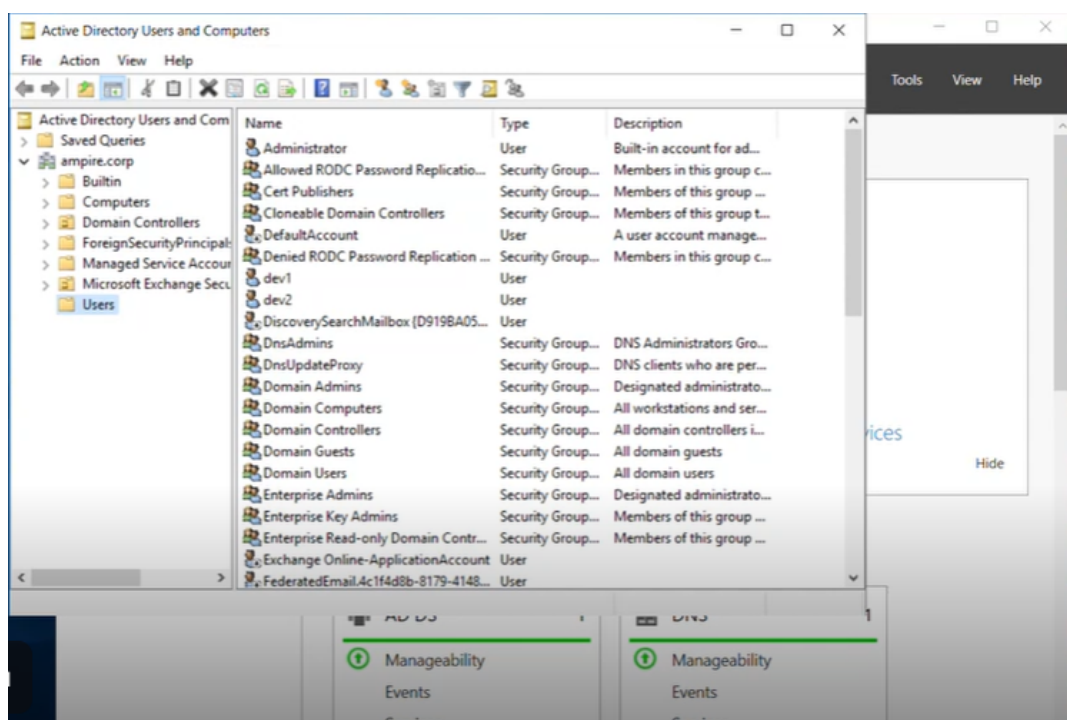


Рис. 2.4: Окно Active Directory Users and Computers

- 3) Правым кликом вызвано контекстное меню, выбран пункт «Reset Password...» -> открылось одноимённое модальное окно с полями «New password», «Confirm password», флажком «User must change password at next logon» и статусом «Account Lockout Status on this Domain Controller Unlocked». В поле New password вводится новый пароль (9 символов).(рис. 2.5).

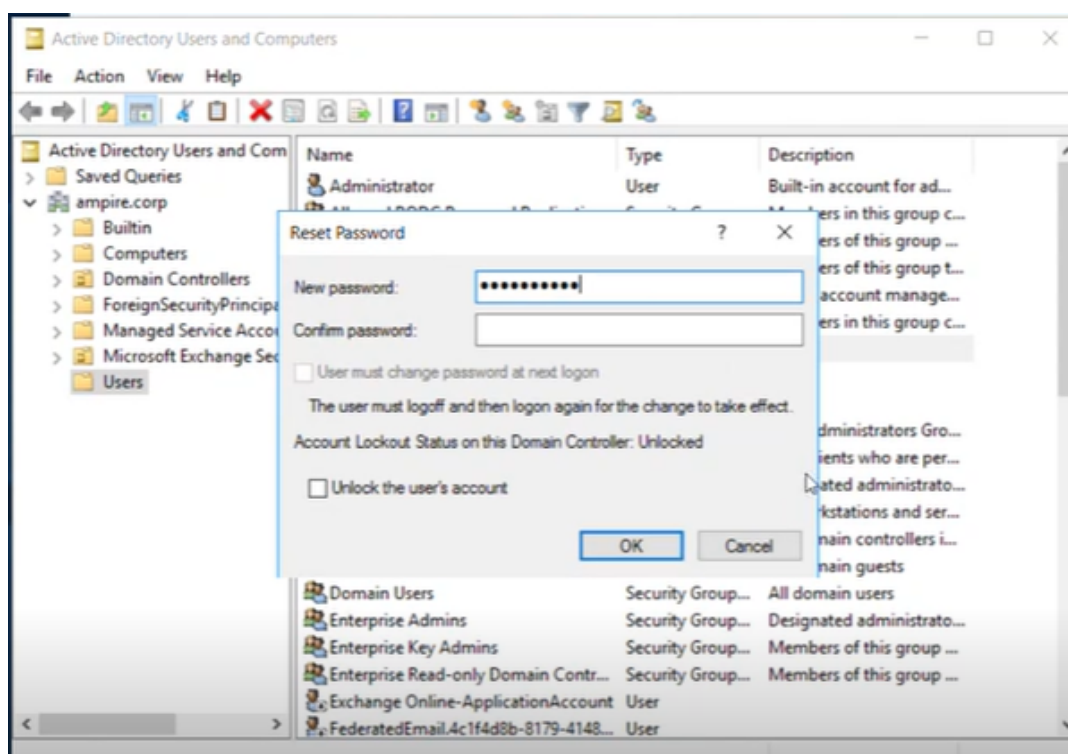


Рис. 2.5: Изменяем пароль

2.2 Последствие. Developer backdoor.

Нарушитель может создать сервис, автоматически запускающий исполняемый файл, который устанавливает Reverse Shell подключение. Новая задача, записанная нарушителем, находится на узле Developer 1 (10.10.4.13) в планировщике задач. (рис. 2.6).

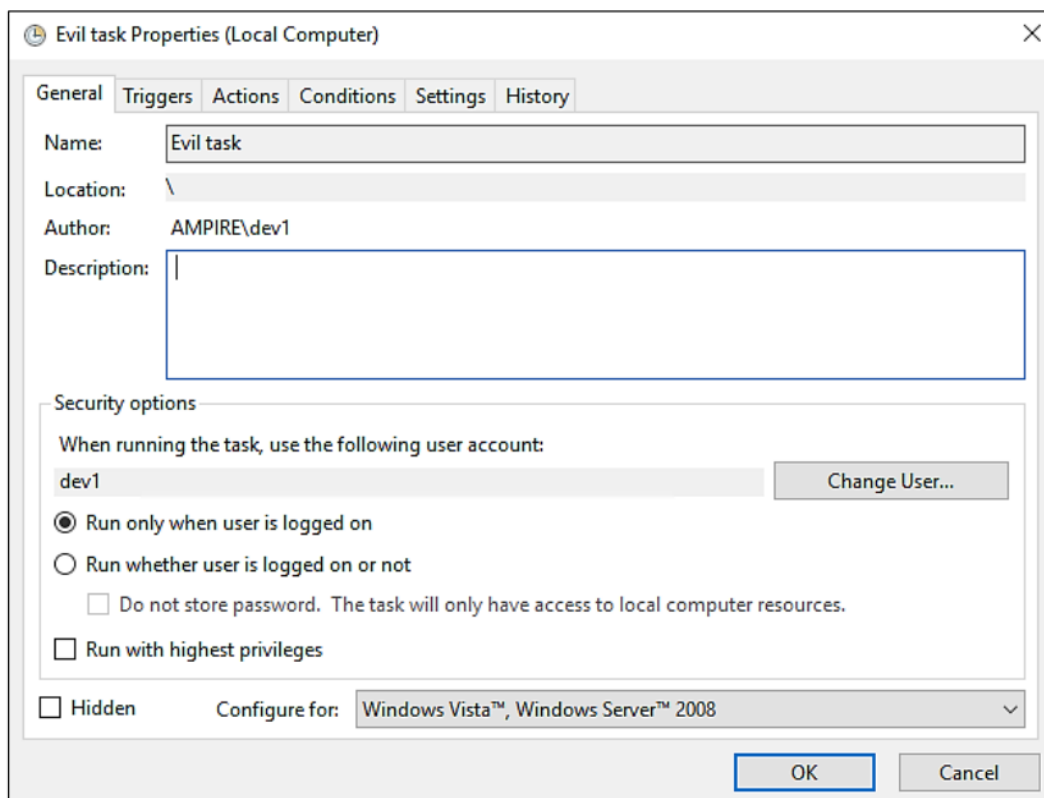


Рис. 2.6: Запуск исполняемого файла в планировщике

В созданной задаче можно обнаружить запуск файла во вкладке «Action» svchosting.exe (рис. 2.7).

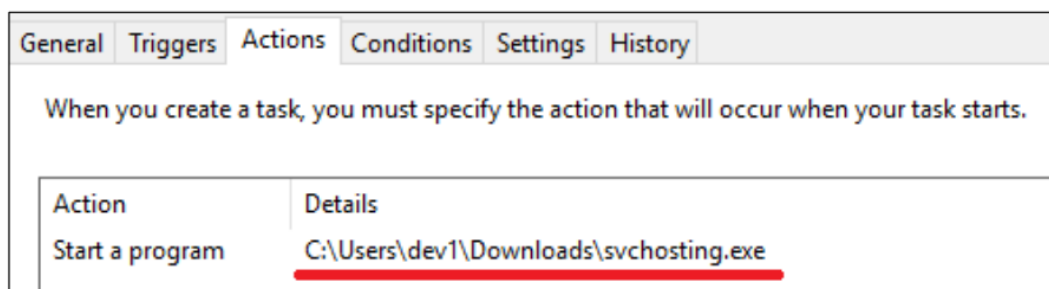


Рис. 2.7: Путь до исполняемого файла

Для устранения полезной нагрузки необходимо удалить задачу из планировщика задач и файл из директории.

Что было сделано:

- 1) Новое RDP-подключение к Developer Workstation 1 (10.10.4.13) (рис. 2.8).

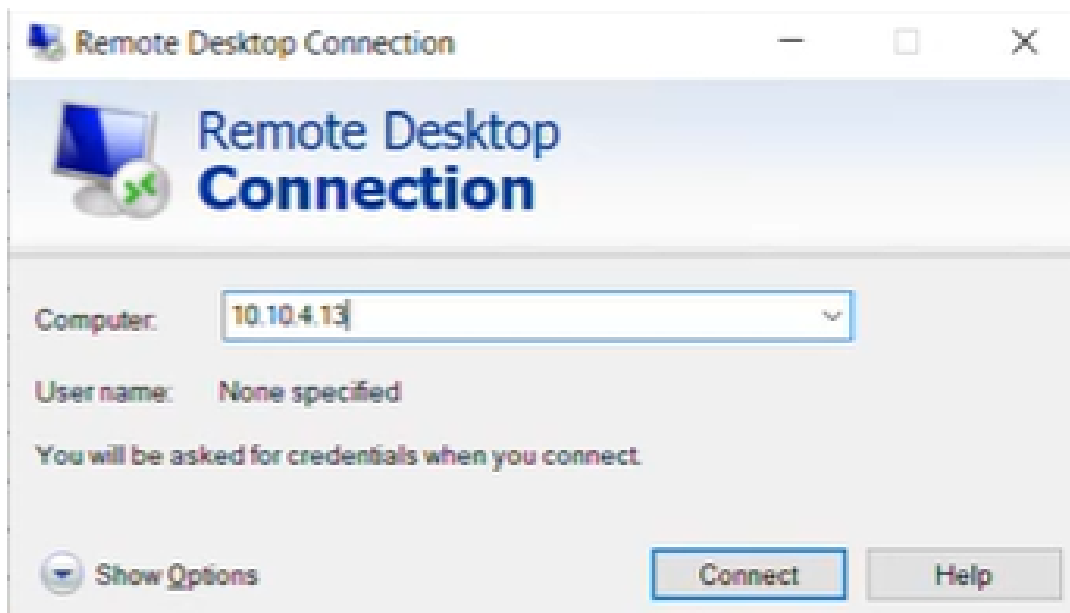


Рис. 2.8: Переходим на удаленный рабочий стол

- 2) Открыть Task Scheduler, вкладка Task Scheduler Library в списке заданий - «Evil task» (рис. 2.9).

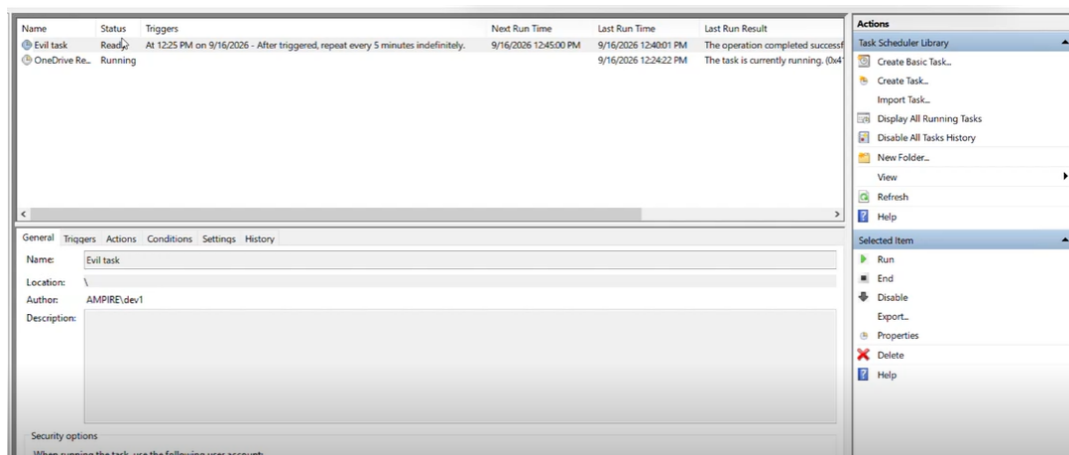


Рис. 2.9: Открыть Task Scheduler

- 3) «Evil task» -> контекстное меню Run End Disable Export... Properties Delete - выбирается пункт Delete, задание удаляется из библиотеки планировщика. (рис. 2.10).

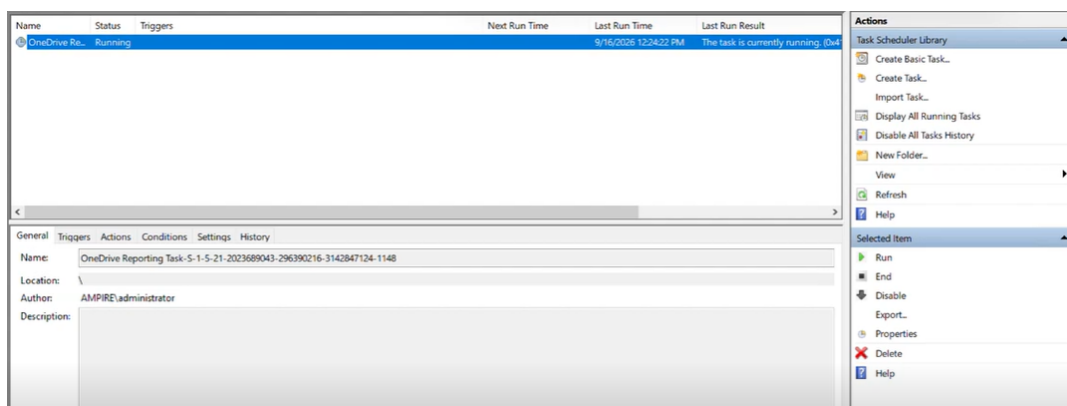


Рис. 2.10: Удаляем Evil task

- 4) Открываем File Explorer, путь This PC -> Downloads в папке два файла - legacy.exe и svchosting.exe. Файл svchosting.exe удаляется, остается только legacy.exe(рис. 2.11).

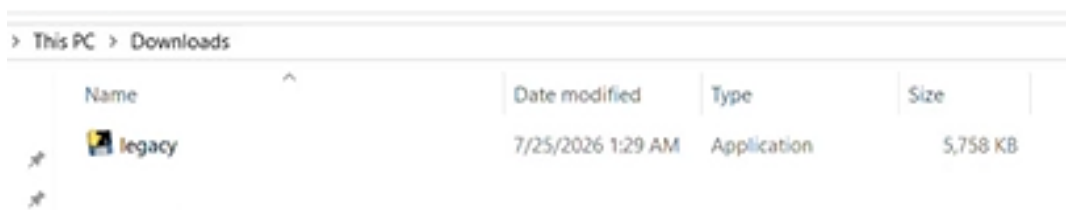


Рис. 2.11: Удаляем svchosting.exe

- 5) Проверяем что последствие «Dev backdoor» зафиксировано платформой как устранённое.(рис. 2.12).

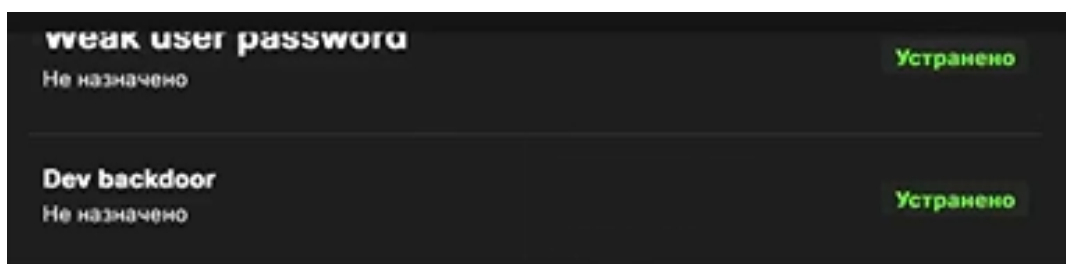


Рис. 2.12: последствие «Dev backdoor» устранённо

2.3 Уязвимость 2. XSS (CVE-2019-17427).

Эксплуатируемая уязвимость - CVE-2019-17427.

В Redmine до версии 3.4.11 и 4.0.x до версии 4.0.4 постоянный XSS существует из-за ошибок форматирования при работе с textile текстом. В данном сценарии используется для включения REST API для эксплуатации следующей уязвимости (рис. 2.13), (рис. 2.14), (рис. 2.15).

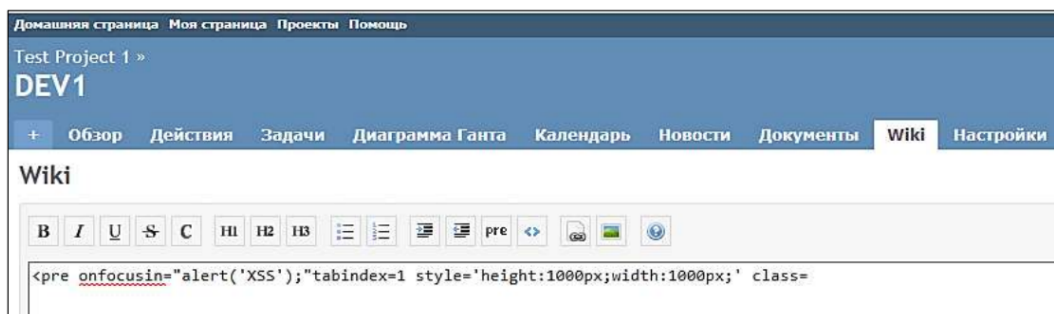


Рис. 2.13: Пример добавления кода, выводящего на экран надпись XSS в wiki-страницу

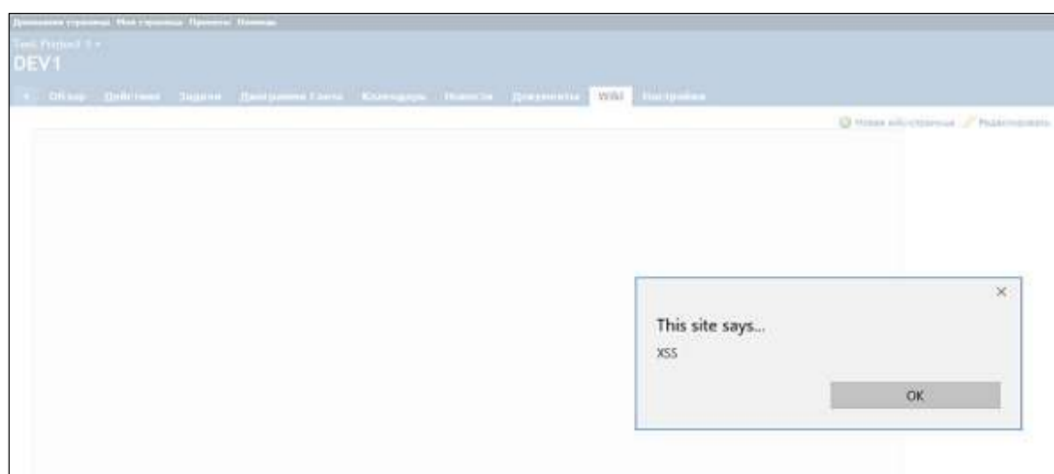


Рис. 2.14: При нажатии на поле wiki-страницы запускается код

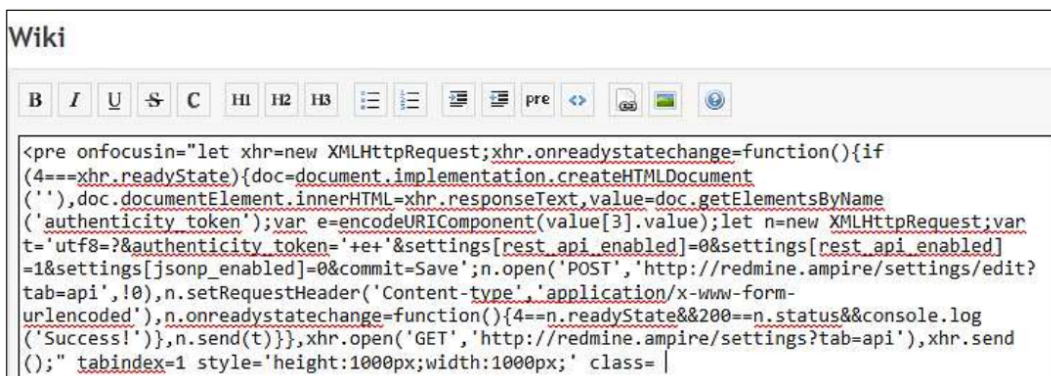


Рис. 2.15: Данный код включает REST API при выполнении с учетной записи admin

Решение: внести изменения в код Redmine.

Необходимо найти обработку текста wiki-страницы при наличии в тексте html-тегов. Из описания уязвимости понятно, что необходимо найти библиотеку для преобразования textile разметки в html. В Redmine за данное преобразование отвечает Redcloth (файл redcloth3.rb в папке /var/www/redmine/lib). В redcloth3.rb представляют интерес следующие строки (рис. 2.16).

```

1214 ALLOWED_TAGS = %w(redpre pre code kbd notextile)
1215 def escape_html_tags(text)
1216   text.gsub(/<\/?([!@#$%^&*(){}~`~'"]+)([>| ])/) { |m| ALLOWED_TAGS.include?(m[1]) ? "<#{m[1]}#{m[2]}" : "&lt;#{m[1]}#{m[2]}" unless m[1].blank? }
1217 end
1218 end

```

Рис. 2.16: Содержимое файла redcloth3.rb

Далее можно удалить тег pre из разрешенных тегов, которые не будут экранированы. Необходимо рассмотреть закрытие уязвимости разработчиками - в репозитории Redmine на Github зайти в Releases и сравнить исправленную версию с уязвимой. В файле redcloth3.rb разработчики внесли следующие изменения (рис. 2.17), (рис. 2.18), (рис. 2.19).

```

lib/redmine/wiki_formatting/textile/redcloth3.rb
@-1213,7 +1213,13 @@ def clean_html( text, tags = BASIC_TAGS )

  ALLOWED_TAGS = %w(redpre pre code kbd notextile)
  def escape_html_tags(text)
    text.gsub!(/<\/?([!\\w]+)[^<>\n]*(>?))/) {|m| ALLOWED_TAGS.include?($2) ? "<#{ $1 }#{ $3 }" : "&lt;#{ $1 }#{ $3 }" unless $3.blank? }
    text.gsub!(/<\/?([!\\w]+)[^<>\n]*(>?))/) do |m|
      if ALLOWED_TAGS.include?($2) && $3.present?
        "<#{ $1 }#{ $3 }"
      else
        "&lt;#{ $1 }#{ $3 }" unless $3.blank?
      end
    end
  end
end
end

```

Рис. 2.17: Изменения в файле redcloth3.rb Код, исправляющий уязвимость CVE-2019-17427

```

user@redmine: /var/www/redmine-3.3.4/lib
GNU nano 2.5.3 File: redcloth3.rb

        pcs << "#{prop}=\"#{ $1.gsub( "'", '\\\'' ) }\""
        break
      end
    end
  end if tags[tag]
    "<#{raw[1]}#{pcs.join " "}">"
  else
    " "
  end
end
end
end

ALLOWED_TAGS = %w(redpre pre code kbd notextile)
def escape_html_tags(text)
  # text.gsub!(/<\/?([!\\w]+)[^<>\n]*(>?))/) {|m| ALLOWED_TAGS.include?($2)
  text.gsub!(/<\/?([!\\w]+)[^<>\n]*(>?))/) do |m|
    if ALLOWED_TAGS.include?($2) && $3.present?
      "<#{ $1 }#{ $3 }"
    else
      "&lt;#{ $1 }#{ $3 }" unless $3.blank?
    end
  end
end
end
end
end

```

Рис. 2.18: Исправление в файле redcloth3.rb

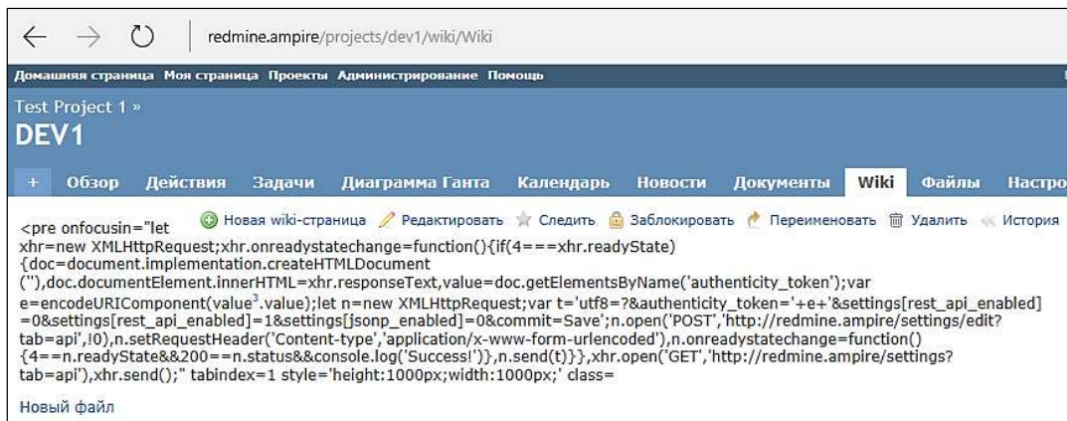


Рис. 2.19: Успешное устранение уязвимости

После внесения изменений необходимо перезапустить службу веб-сервера:
`sudo systemctl restart nginx.service.`

Что было сделано:

- 1) Через терминал SSH-подключение к серверу Redmine (10.10.2.15), рабочая директория `var/www/redmine/lib`; в nano открыт файл `redcloth3.rb` и редактируем.(рис. 2.20), (рис. 2.21).

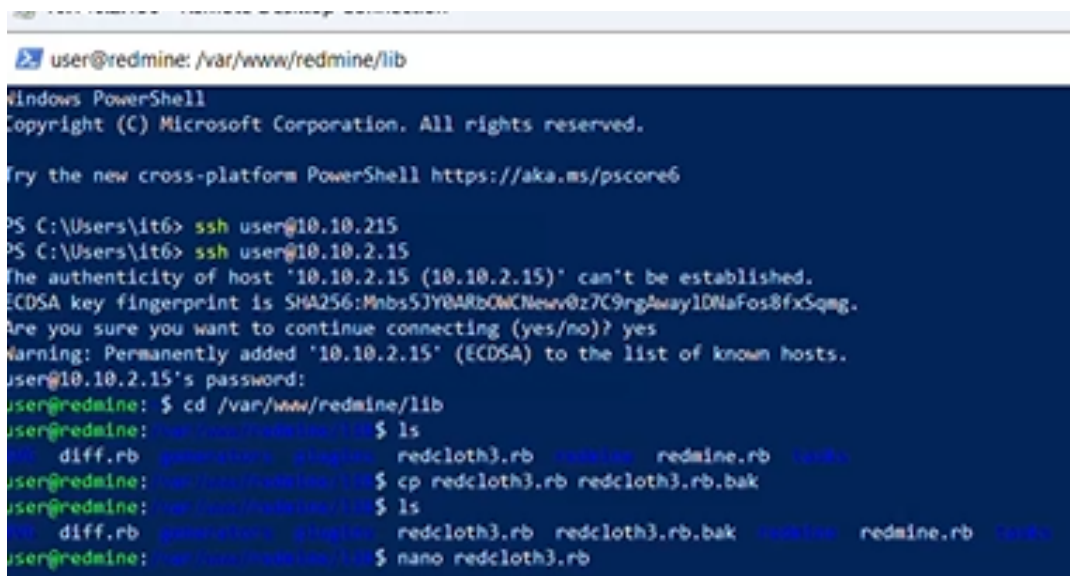


Рис. 2.20: Подключение к серверу Redmine

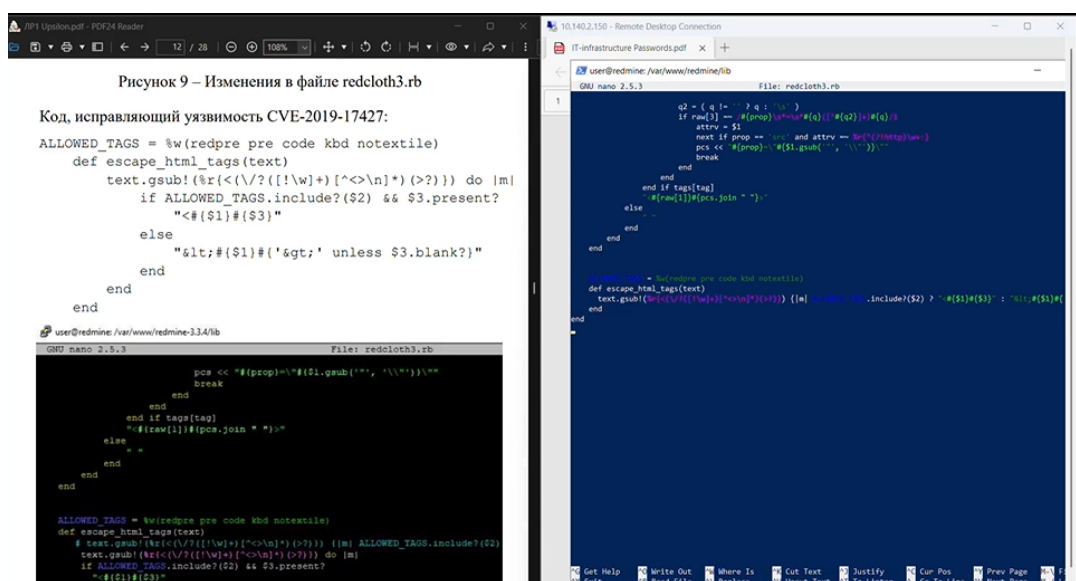


Рис. 2.21: Файл redcloth3.rb

исходная строка `text.gsub!(/%r{((?!w+)[^n])()}) {m ALLOWED_TAGS.include($2) #{ $1 }#{ $3 } <#{ $1 }#{ ' >' unless $3.blank?}` комментируется (добавляется # в начале строки); (рис. 2.22).

ниже дописывается новый блок кода

`text.gsub!(/%r{((?!w+)[^n])()}) do m`

`if ALLOWED_TAGS.include($2) && $3.present`

`#{ $1 }#{ $3 }`

`else`

`<#{ $1 }#{ ' >' unless $3.blank?}`

`end`

`end`

```

#!/usr/bin/perl -w(redpre pre code kbd notextile)
def escape_html_tags(text)
  # text.gsub!(/<\/?([!@%&'+<\/?>])/) { |m| ALLOWED_TAGS.include?(m) ? "<#{$1}#{$2}" : "<#{$1}#{$2}" }
  text.gsub!(/<\/?([!@%&'+<\/?>])/) do |m|
    if ALLOWED_TAGS.include?(m) && $3.present?
      "<#{$1}#{$2}"
    else
      "<#{$1}#{"&gt;" unless $3.blank?}"
    end
  end
end
end
end
end

```

Рис. 2.22: Файл redcloth3.rb отредактированный

2) `sudo systemctl restart nginx.service` — служба перезапущена.(рис. 2.23).

```

Use "fg" to return to nano.
Use "fg" to return to nano.

[1]+  Stopped                  nano redcloth3.rb
user@redmine:~/redmine$ nano redcloth3.rb
user@redmine:~/redmine$ sudo systemctl restart nginx.service
[sudo] password for user:
Failed to restart nginx.service: Unit nginx.service not found.
user@redmine:~/redmine$ sudo systemctl restart nginx.service

```

Рис. 2.23: Перезапускаем службу

3) Переходим по правильному адресу и успешно заходим на web страницу, выполнен вход в консоль администратора Redmine. На сервере лабораторной работы, так же показывает положительный результат(рис. 2.24).

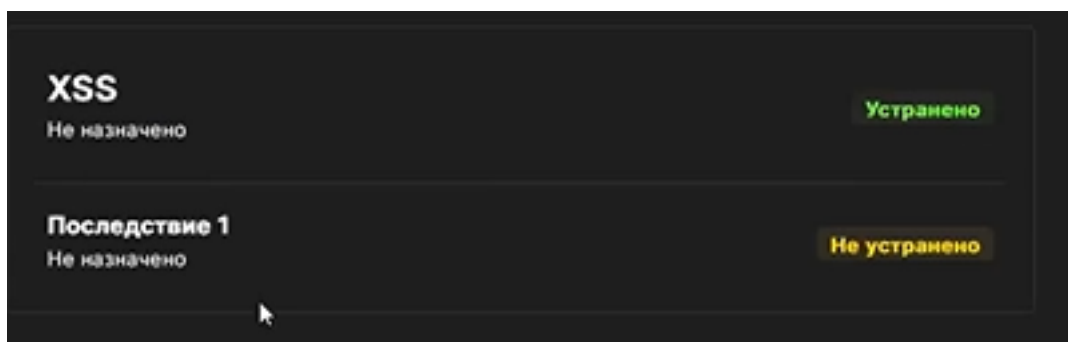


Рис. 2.24: Успешное устранение уязвимости

2.4 Последствие. Redmine User.

Данная полезная нагрузка заключается в том, что нарушитель создает пользователя на портале Redmine. Пользователь, обладающий правами администратора, имеет неограниченный доступ к пользовательской базе.

Примечание: способ закрытия полезной нагрузки «Redmine User» не будет действовать до внесения изменений по закрытию уязвимости «Атака XSS»

Для обнаружения добавления нового привилегированного пользователя, достаточно зайти в консоль администратора Redmine по ссылке (<http://redmine.ampire.corp/login>), перейти в раздел «Administration» - «Users» и посмотреть список существующих пользователей (рис. 2.25).

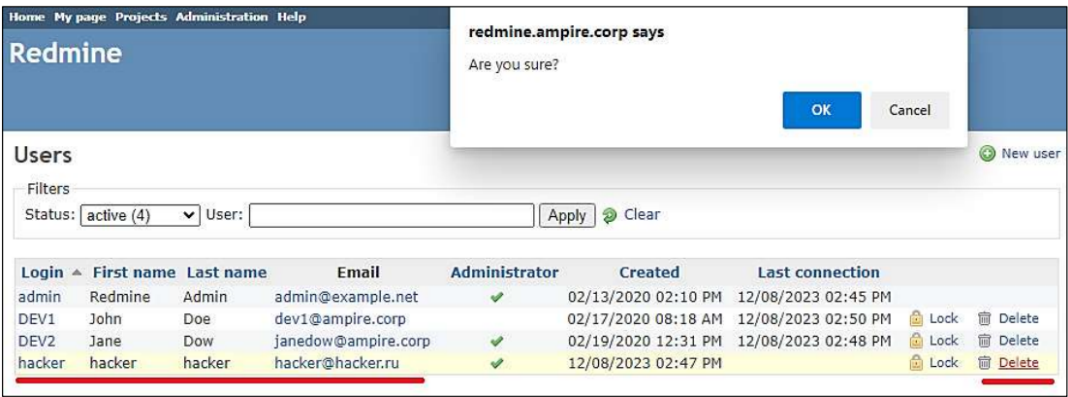


The screenshot shows the 'Users' management page in Redmine. It includes a filter section with 'Status: active (4)' and an empty 'User' search box. Below the filters is a table listing four users: 'admin', 'DEV1', 'DEV2', and 'hacker'. The 'hacker' user is highlighted in yellow.

Login	First name	Last name	Email
admin	Redmine	Admin	admin@example.net
DEV1	John	Doe	dev1@ampire.corp
DEV2	Jane	Dow	janedow@ampire.corp
hacker	hacker	hacker	hacker@hacker.ru

Рис. 2.25: Список пользователей Redmine

Для нейтрализации полезной нагрузки необходимо удалить созданного пользователя «hacker» через веб-интерфейс Redmine (рис. 2.26).



The screenshot shows the 'Users' page with a confirmation dialog box on top asking 'Are you sure?'. The dialog has 'OK' and 'Cancel' buttons. Below the dialog, the 'Users' table is visible, showing additional columns: 'Administrator', 'Created', and 'Last connection'. The 'hacker' user is highlighted in yellow and has 'Lock' and 'Delete' icons next to it.

Login	First name	Last name	Email	Administrator	Created	Last connection
admin	Redmine	Admin	admin@example.net	✓	02/13/2020 02:10 PM	12/08/2023 02:45 PM
DEV1	John	Doe	dev1@ampire.corp	✓	02/17/2020 08:18 AM	12/08/2023 02:50 PM
DEV2	Jane	Dow	janedow@ampire.corp	✓	02/19/2020 12:31 PM	12/08/2023 02:48 PM
hacker	hacker	hacker	hacker@hacker.ru	✓	12/08/2023 02:47 PM	

Рис. 2.26: Удаление пользователя hacker

В результате удаления созданного пользователя «hacker» успешно нейтрализовано последствие Redmine User.

Что было сделано:

- 1) В разделе Administration -> Users список пользователей admin, DEV1, DEV2, hacker (email hacker@hacker.ru, дата создания 16.09.2026 1225 PM, последнее подключение 1258 PM) — строка hacker подсвечена как посторонняя. (рис. 2.27).

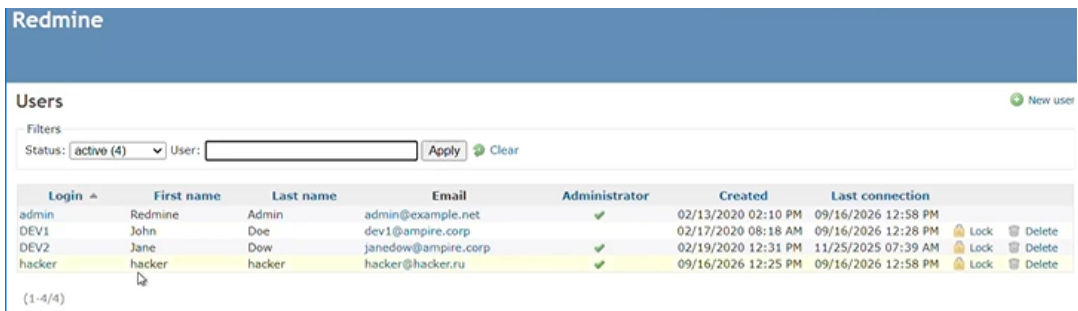


Рис. 2.27: Находим пользователя hacker

- 2) Удаляем hacker. По кнопке Delete в строке hacker вызывается подтверждающий диалог браузера «redmine.ampire.corp says Are you sure» с кнопками OKCancel; нажимается OK — учётная запись удаляется.(рис. 2.28).

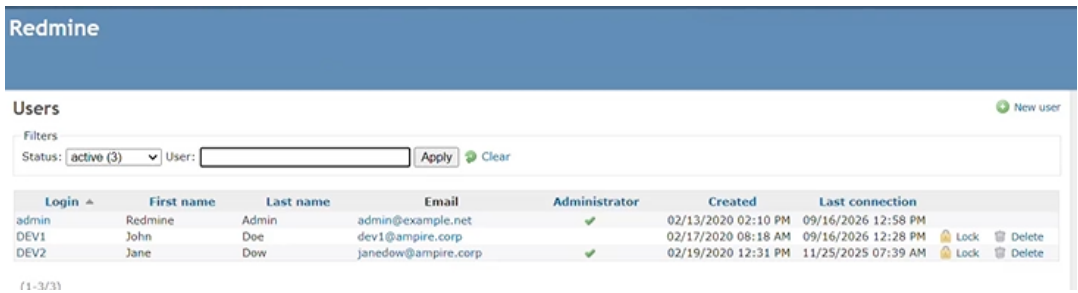


Рис. 2.28: Удаляем hacker

- 3) Переходим на сервер лабораторной работы. Последствие Redmine User устранено(рис. 2.29).

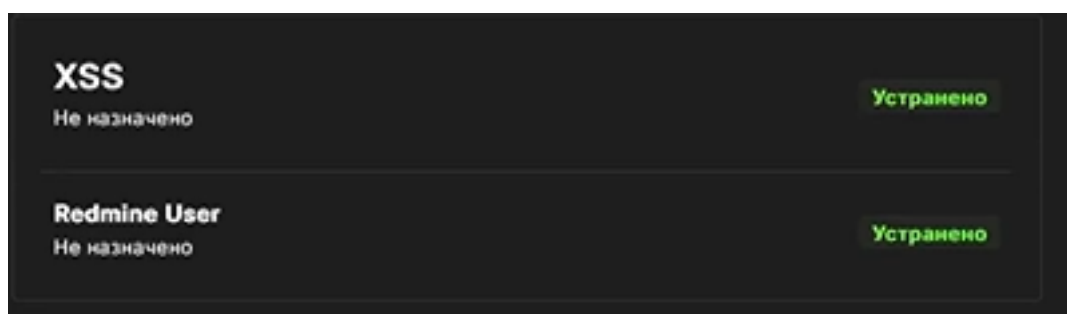


Рис. 2.29: Последствие Redmine User устранено

2.5 Уязвимость 3. Blind SQL (CVE-2019-18890).

Эксплуатируемая уязвимость - CVE-2019-18890.

В Redmine до версии 3.2.9 и 3.3.x до версии 3.3.10 уязвимость позволяет пользователям Redmine получать доступ к защищенной информации с помощью сгенерированного объектного запроса. Уязвимость реализуется посимвольным перебором с замером времени ответа. В данном сценарии данная уязвимость используется для получения конфиденциальной информации из БД, минуя разграничение доступа Redmine (рис. 2.30),(рис. 2.31).

Время прихода пакета является индикатором: при запоздании пакета - символ подобран верно, иначе - перебор продолжается.

F12 DOM Explorer Console Debugger Network Performance Memory Emulation Experiments							
Content type							
Name	Protocol	Method	Result	Content type	Received	Time	
issues.xml?project id=1&subproject id=2.3-SLEEP(2) http://redmine.ample/	HTTP	GET	200 OK	application/xml		4.09 s	

Рис. 2.30: При отправке запроса SLEEP(2) время ожидания ответа возрастает до 4 секунд, что свидетельствует об инъекции


```
end

# Returns the SQL sort order that should be prepended for grouping
def group_by_sort_order
  if column = group_by_column
    order = (sort_criteria_order_for(column.name) || column.default_order || 'asc').try(:upcase)
    Array(column.sortable).map {|s| "#{s} #{order}" }
  end
end

# Returns true if the query is a grouped query
def grouped?
  !group_by_column.nil?
end

def group_by_column
  groupable_columns.detect {|c| c.groupable == c.name.to_s == group_by }
end

def group_by_statement
  group_by_column.try(:groupable)
end

def project_statement
  project_clauses = []
  if project && !project.descendants.active.empty?
    if has_filter?("subproject_id")
      case operator_for("subproject_id")
      when '='
        # include the selected subprojects
        # ids = [project.id] + values_for("subproject_id").each{|:to_i|
        ids = [project.id] + values_for("subproject_id").map{|:to_i|
        project_clauses << "(#{Project.table_name}.id IN (#{ids.join(',')})"
      when '!='
        # main project only
        project_clauses << "(#{Project.table_name}.id = #{project.id}
    else
  end
end
```

Рис. 2.32: Содержимое файла query.rb с исправлением уязвимости

Из вышеупомянутого рисунка следует, что выделенный участок кода отвечает за передачу значений в запрос в случае наличия параметра subproject_id. В данном случае следует добавить фильтрацию значений и закомментировать код.

После внесения изменений необходимо перезапустить службу веб-сервера: `sudo systemctl restart nginx.service`.

Что было сделано:

- 1) Повторно выполняем SSH-подключение к 10.10.2.15, переход в `varwwwredmineappmodel` `cp query.rb query.rb.bak`; открытие query.rb в nano.(рис. 2.33).

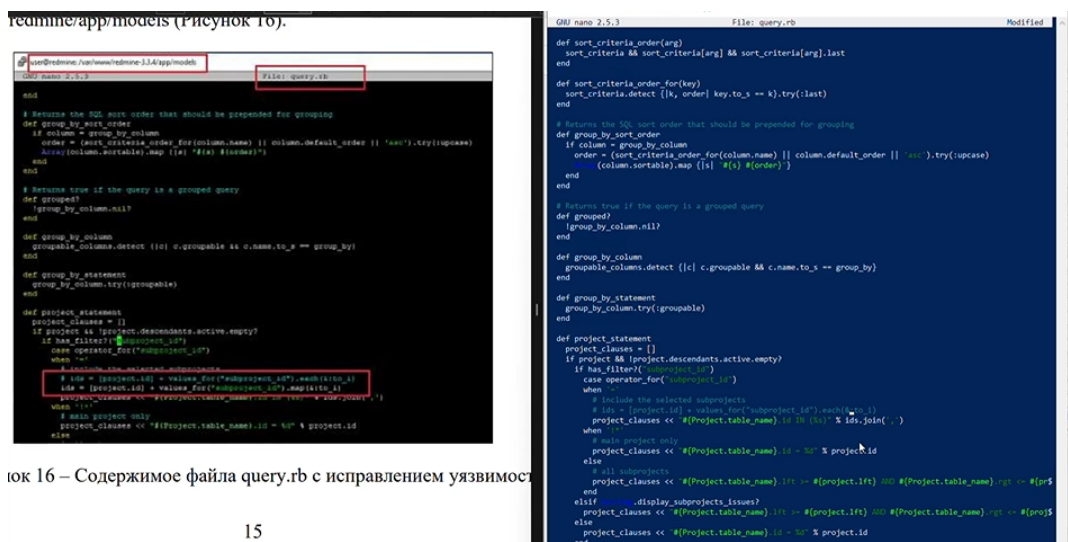


Рис. 2.33: Файл query.rb

2) В методе project_statement вносится точечная правка

Строка `ids = [project.id] + values_for(subproject_id).each(&to_i)` комментируется;
 Заменяется на `ids = [project.id] + values_for(subproject_id).map(&to_i)`.

Суть исправления метод `.each(&to_i)` не изменяет содержимое массива (возвращает исходные, потенциально произвольные строковые значения), тогда как `.map(&to_i)` принудительно приводит каждое значение параметра `subproject_id` к целому числу, что и закрывает возможность подстановки SQL-конструкций через этот параметр. (рис. 2.34).

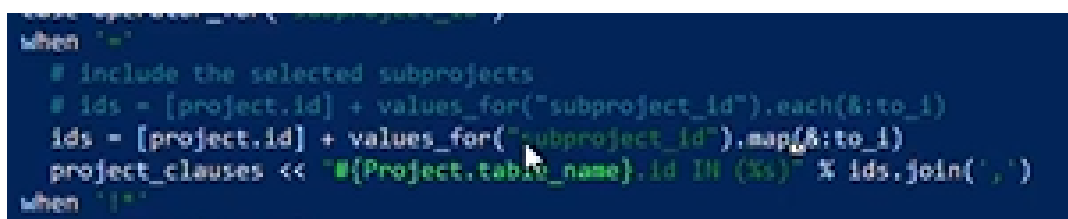


Рис. 2.34: Исправляем query.rb

3) `sudo systemctl restart nginx.service` — служба перезапущена. (рис. 2.35).

```

user@redmine: /usr/local/nvm/node-v10.16.0/bin $ nano query.rb
user@redmine: /usr/local/nvm/node-v10.16.0/bin $ sudo systemctl restart nginx.service

```

Рис. 2.35: Перезапускаем службу

- 4) Переходим по правильному адресу и успешно заходим на web страницу, выполнен вход в консоль администратора Redmine. На сервере лабораторной работы, так же показывает положительный результат(рис. 2.36), (рис. 2.37).

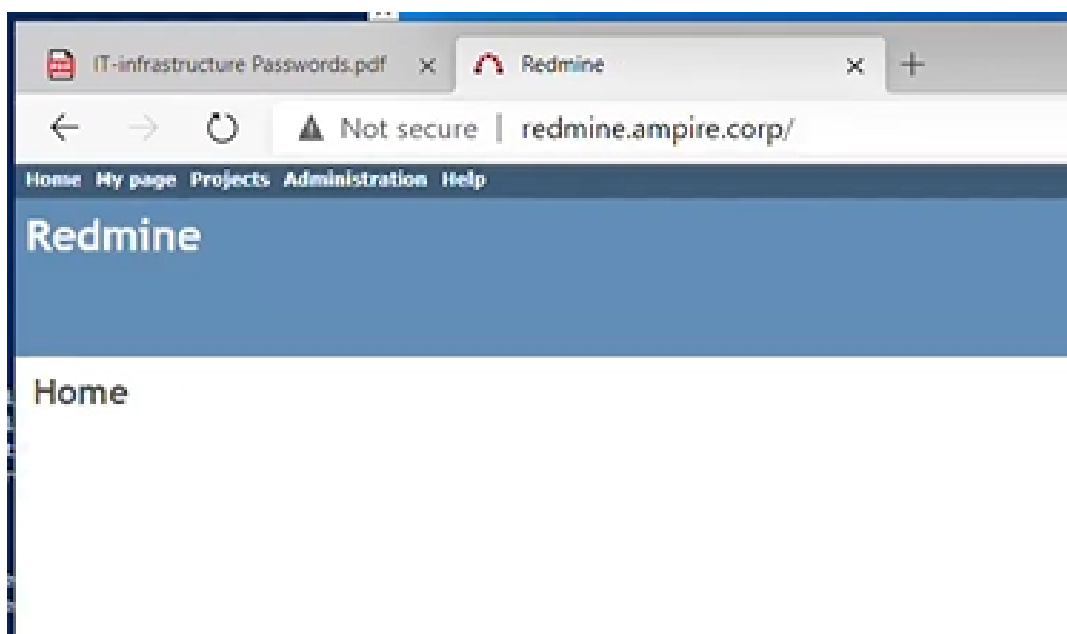


Рис. 2.36: Переходим на web страницу

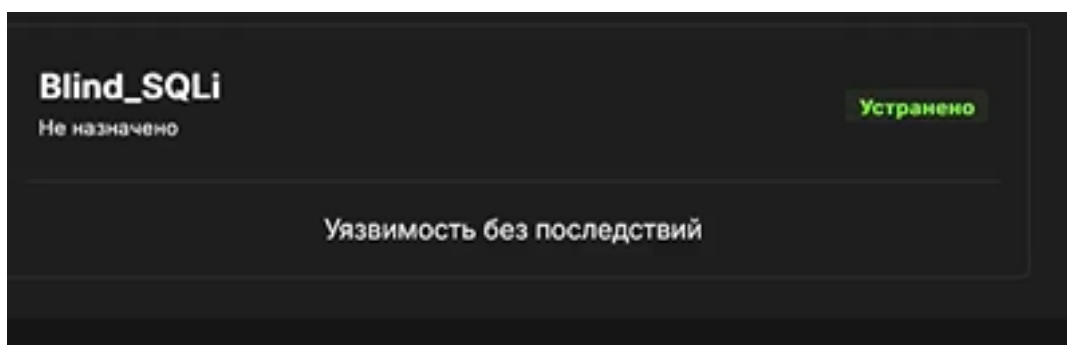


Рис. 2.37: Успешное устранение уязвимости

3 Мониторинг

В процессе мониторинга, наша команда пыталась определить какие системы были затронуты нарушителем, что выдавало его присутствие большим числом откликов и связей между собой. У нас получилось установить 4 отчета мониторинга системы: от момента как нарушитель попал в систему, до описания всех уязвимостей что были в системе.

Помимо непосредственного устранения уязвимостей, в рамках лабораторной работы велась регистрация выявленных инцидентов информационной безопасности во вкладке «Инциденты» платформы Ampire. Источником данных для заполнения карточек инцидентов служили события, зафиксированные программно-аппаратным комплексом обнаружения вторжений ViPNet IDS NS.

3.1 Анализ событий ViPNet IDS NS

В разделе «События» ViPNet IDS NS средствами фильтра было настроено отображение событий за последние 24 часа с возможностью уточнения по IP-адресу источника, порта, получателя, домена, MAC-адреса и страны (рис. 3.1).

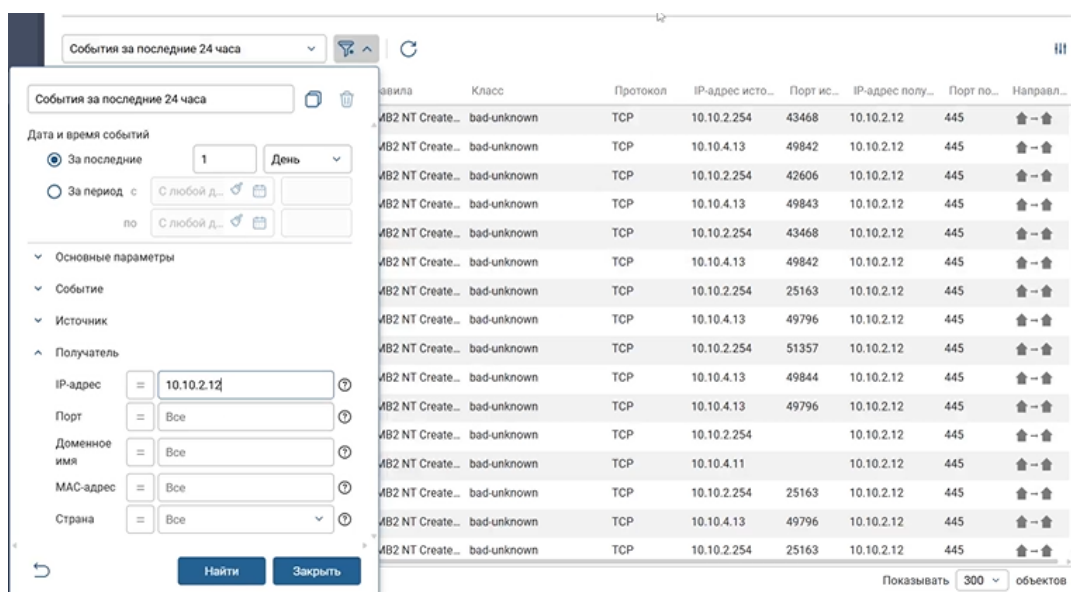


Рис. 3.1: Панель фильтрации событий в ViPNet IDS NS

В ходе анализа выявлена серия однотипных повторяющихся событий класса network-scan, зарегистрированных с интервалом около шести минут (рис. 3.2).

События

События за последние 24 часа

У...	Дата и время	Ид	Код событ...	К...	Название правила	Класс
●	13:09:59.907 16...		3227018	1	ET SCAN Behavioral Unusu...	network-scan
●	13:03:51.304 16...		3227018	1	ET SCAN Behavioral Unusu...	network-scan
●	12:57:42.661 16...		3227018	1	ET SCAN Behavioral Unusu...	network-scan
●	12:51:33.932 16...		3227018	1	ET SCAN Behavioral Unusu...	network-scan
●	12:45:25.357 16...		3227018	1	ET SCAN Behavioral Unusu...	network-scan
●	12:39:16.428 16...		3227018	1	ET SCAN Behavioral Unusu...	network-scan
●	12:33:07.592 16...		3227018	1	ET SCAN Behavioral Unusu...	network-scan
●	12:26:58.774 16...		3227018	1	ET SCAN Behavioral Unusu...	network-scan

Рис. 3.2: Список событий класса network-scan за период наблюдения

Детальный просмотр одного из событий (12:26:58.774, 16.09.2026) показал следующие параметры: интерфейс захвата — eth2, протокол — TCP, тип события — сигнатурное, уровень важности — низкий, код события — 3227018. Соответствующее правило анализа — ET SCAN Behavioral Unusually fast Terminal Server Traffic Potential Scan or Infection (Inbound) var1 (класс network-scan, группа scan) — обнаруживает факт сканирования RDP-порта (рис. 3.3).

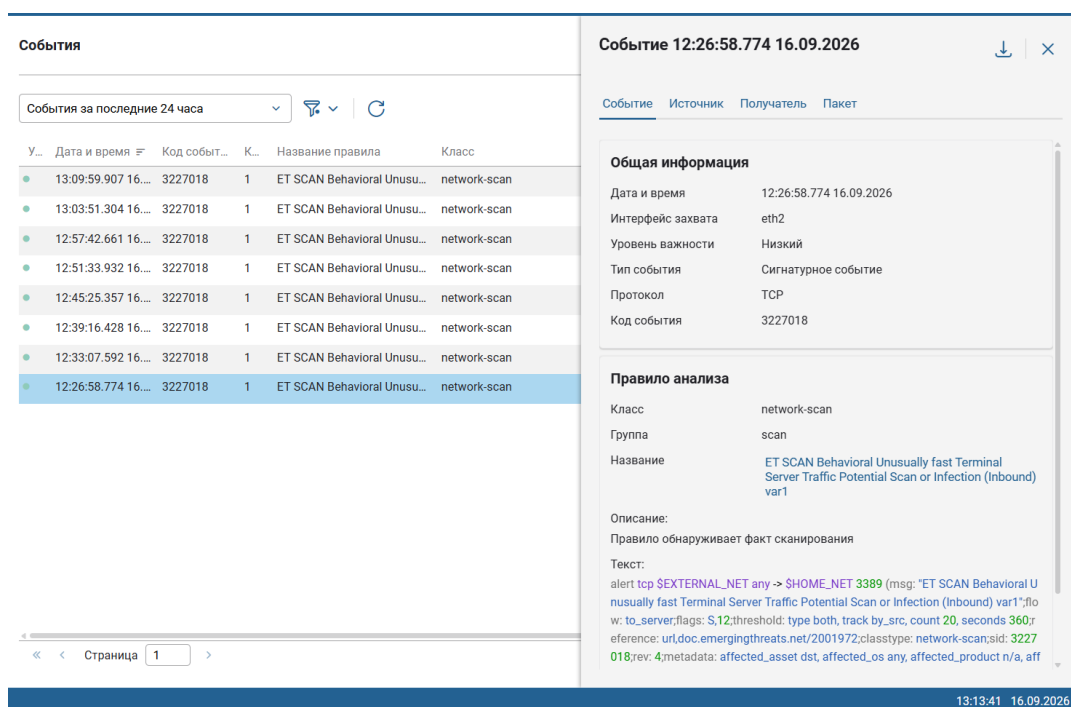


Рис. 3.3: Карточка события с полным текстом сработавшего правила

Сопоставление источника и получателя данных событий показало, что сканирование велось с внешнего адреса 195.239.174.11 в адрес рабочей станции 10.10.4.11 на порт 3389 (RDP) (рис. 3.4).

●	12:39:16.428 16...	3227018	1	ET SCAN Behavioral Unusu...	network-scan	TCP	195.239.174.11	37424	10.10.4.11	3389	🔍 → 🏠
●	12:33:07.592 16...	3227018	1	ET SCAN Behavioral Unusu...	network-scan	TCP	195.239.174.11	35940	10.10.4.11	3389	🔍 → 🏠
●	12:26:58.774 16...	3227018	1	ET SCAN Behavioral Unusu...	network-scan	TCP	195.239.174.11	60350	10.10.4.11	3389	🔍 → 🏠

Рис. 3.4: События сканирования RDP-порта узла 10.10.4.11 с внешнего адреса

Дополнительно был применён фильтр по получателю событий с IP-адресом 10.10.2.12 (MS FileServer). В результате обнаружена серия событий класса bad-unknown с сигнатурой SMB2 NT Create AndX Request..., источниками которых выступали адреса 10.10.2.254 и 10.10.4.13, порт назначения — 445 (SMB) (рис. 3.5).

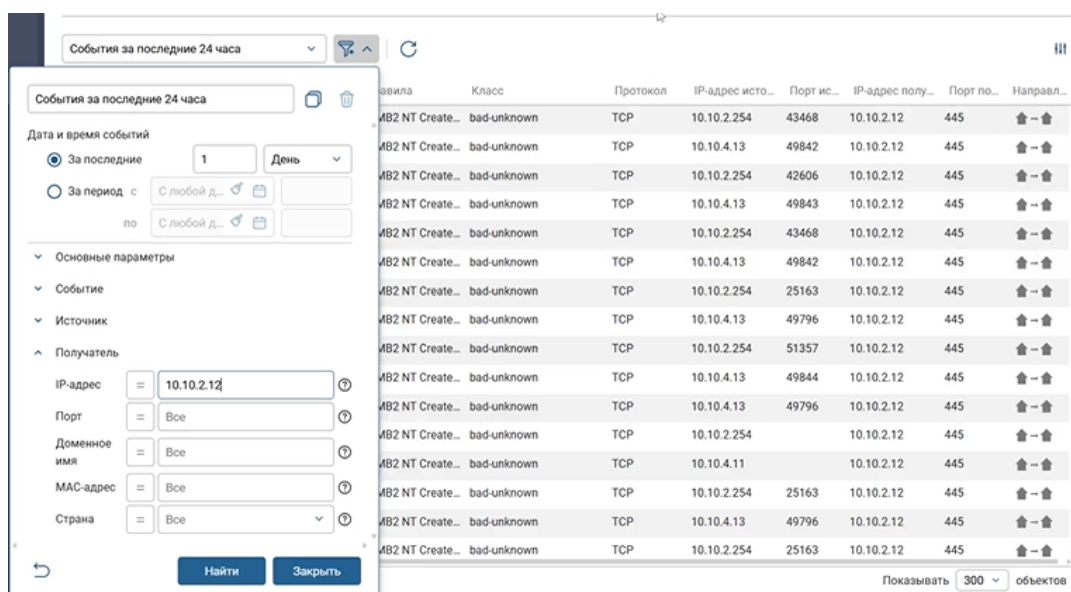


Рис. 3.5: События обращения к SMB-ресурсам файлового сервера (порт 445)

Также в трафике, направленном на веб-сервер Redmine (10.10.2.15:80), зафиксированы события класса web-application-attack: AM EXPLOIT Generic Possi... и AM EXPLOIT Possible Red..., с источниками 10.10.2.254 и 10.10.4.11 (рис. 3.6).

12:25:32.478 16...	3106503	1	AM EXPLOIT Generic Possi...	web-application-attack	TCP	10.10.2.254	9650	10.10.2.15	80	→←
12:25:32.478 16...	3267800	1	AM EXPLOIT Possible Red...	web-application-attack	TCP	10.10.4.11	62495	10.10.2.15	80	→←
12:25:32.478 16...	3106503	1	AM EXPLOIT Generic Possi...	web-application-attack	TCP	10.10.4.11	62495	10.10.2.15	80	→←
12:25:32.478 16...	3267795	1	AM EXPLOIT Generic Possi...	web-application-attack	TCP	10.10.4.11	62495	10.10.2.15	80	→←

Рис. 3.6: События класса web-application-attack, зафиксированные на веб-сервере Redmine

3.2 Регистрация инцидентов

На основании результатов анализа событий ViPNet IDS NS и сопоставления их со сценарием атаки (Сценарий №5) на платформе Ampire были зарегистрированы карточки инцидентов через форму «Добавление инцидента».

По результатам работы было зарегистрировано четыре инцидента, соответствующих этапам сценария атаки:

Инцидент 1. «Атака на Manager Workstation 1 на базе Developer» (автор — Жу-

кова Арина, 16.09.2026 12:25). Описание: атака на узел Manager Workstation 1 через файловый сервер с эксплуатацией уязвимости слабого пароля пользователя; атакующий — внешний нарушитель, действующий от лица узла Developer. Источник — 10.10.4.13, поражённый актив — 10.10.4.11. Рекомендации: смена пароля пользователя на более сложный, блокировка IP-адреса атакующего на межсетевом экране, проверка целостности файлов и конфигураций узла, аудит учётных записей на предмет несанкционированного доступа (рис. 3.7).

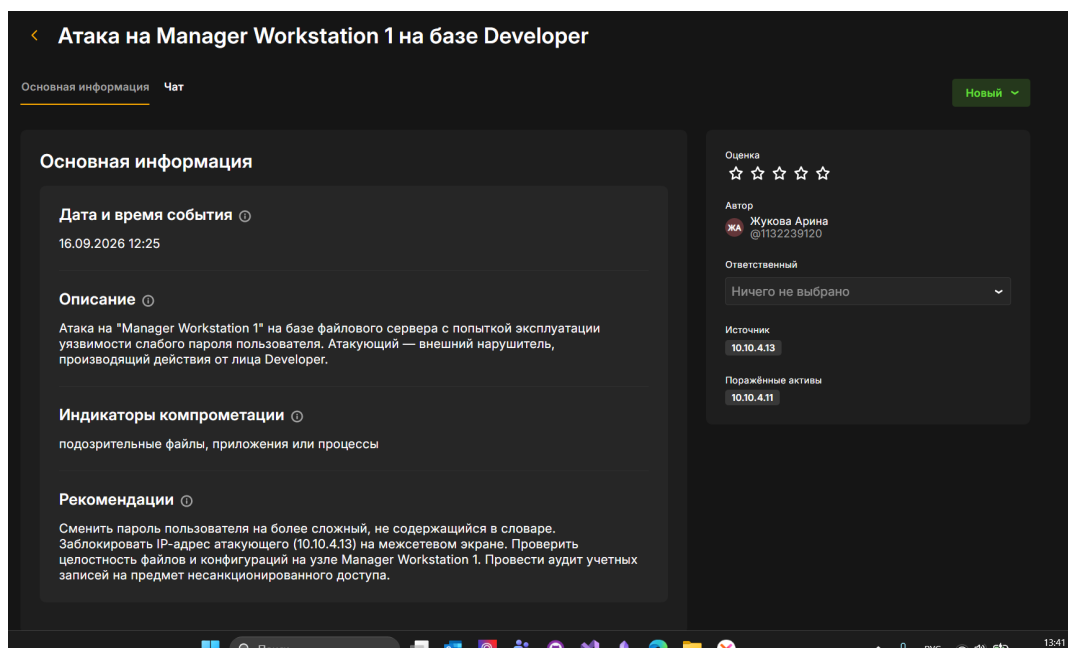


Рис. 3.7: Карточка инцидента «Атака на Manager Workstation 1 на базе Developer»

Инцидент 2. «Атака на Developer на базе Kali» (автор — Садова Диана, 16.09.2026 12:26). Описание: атака на рабочую станцию Developer с внешнего устройства злоумышленника под управлением Kali Linux, направленная на узел Manager Workstation 1. Источник — 195.239.174.11 (Kali), поражённый актив — 10.10.4.11 (Manager Workstation 1). Рекомендации: смена пароля, проверка целостности файлов узла Developer, аудит учётных записей (рис. 3.8).

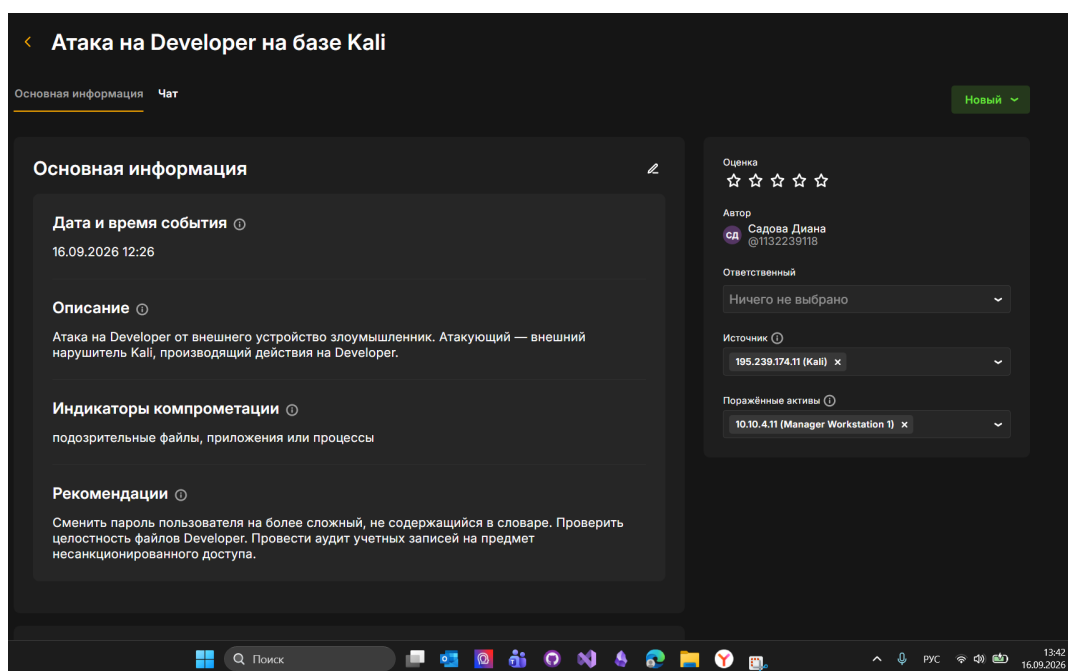


Рис. 3.8: Карточка инцидента «Атака на Developer на базе Kali»

Инцидент 3. «Атака на веб-сервер redmine.ampire.corp с попыткой эксплуатации уязвимости SQL-инъекции» (автор — Жукова Арина, 16.09.2026 12:25). Описание: атака на веб-сервер redmine.ampire.corp на базе Redmine с попыткой эксплуатации SQL-инъекции; атакующий — внешний нарушитель, использующий автоматизированный инструмент python-requests/2.31.0. Источник — 10.10.4.11, поражённый актив — 10.10.2.15. Индикаторы компрометации: подозрительные приложения (использование python-requests/2.31.0), аномально высокое количество обращений к одному файлу. Рекомендации: блокировка IP-адреса атакующего, проверка веб-сервера на наличие уязвимостей SQL-инъекций, обновление Redmine и его компонентов, аудит логов веб-сервера и базы данных, усиление валидации входных данных на стороне сервера (рис. 3.9).

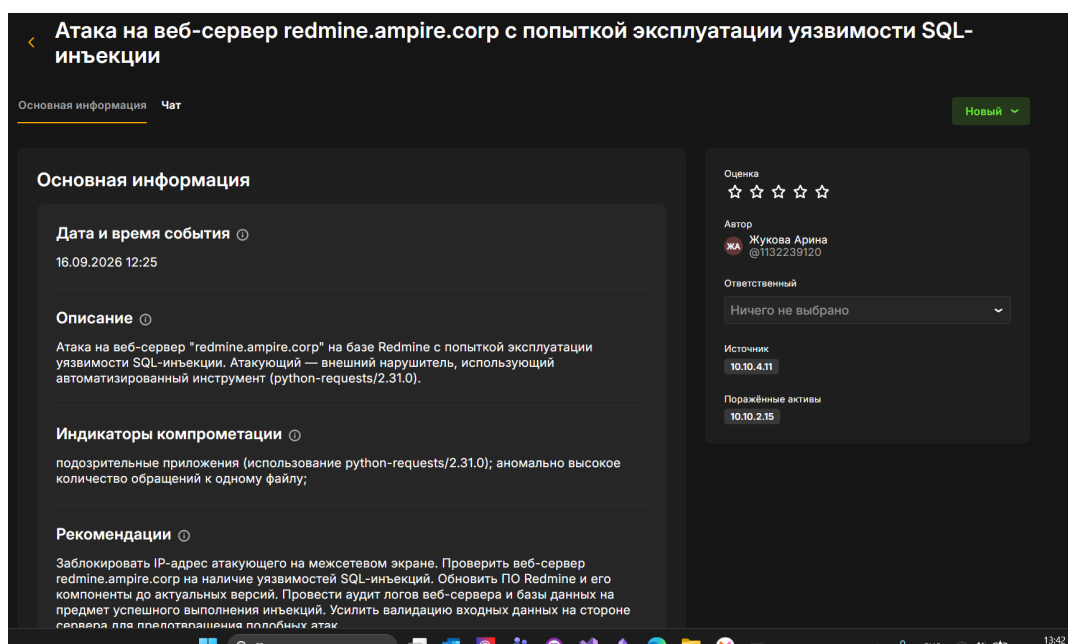


Рис. 3.9: Карточка инцидента «Атака на веб-сервер redmine.ampire.corp с попыткой эксплуатации уязвимости SQL-инъекции»

Инцидент 4. «Атака Blind SQL-инъекция на сервере Redmine» (автор — Садова Диана, 16.09.2026 12:25). Описание: эксплуатируемая уязвимость — CVE-2019-18890 (Redmine до версии 3.2.9 и 3.3.x до версии 3.3.10); атакующий — внутренний нарушитель. Зафиксированные события: ET WEB_SERVER Possible SQL Injection Attempt SELECT FROM и ET WEB_SERVER SQL Injection Select Sleep Time Delay. Источник — 10.10.4.11 (Manager Workstation 1), поражённый актив — 10.10.2.15 (Redmine Server). Индикатор компрометации: аномально высокое количество обращений к одному файлу. Рекомендации: внести изменения в код Redmine — найти обработку параметра subproject_id в файле query.rb (директория /var/www/redmine/app/models), добавить фильтрацию значений параметра и закомментировать уязвимый участок кода (рис. 3.10).

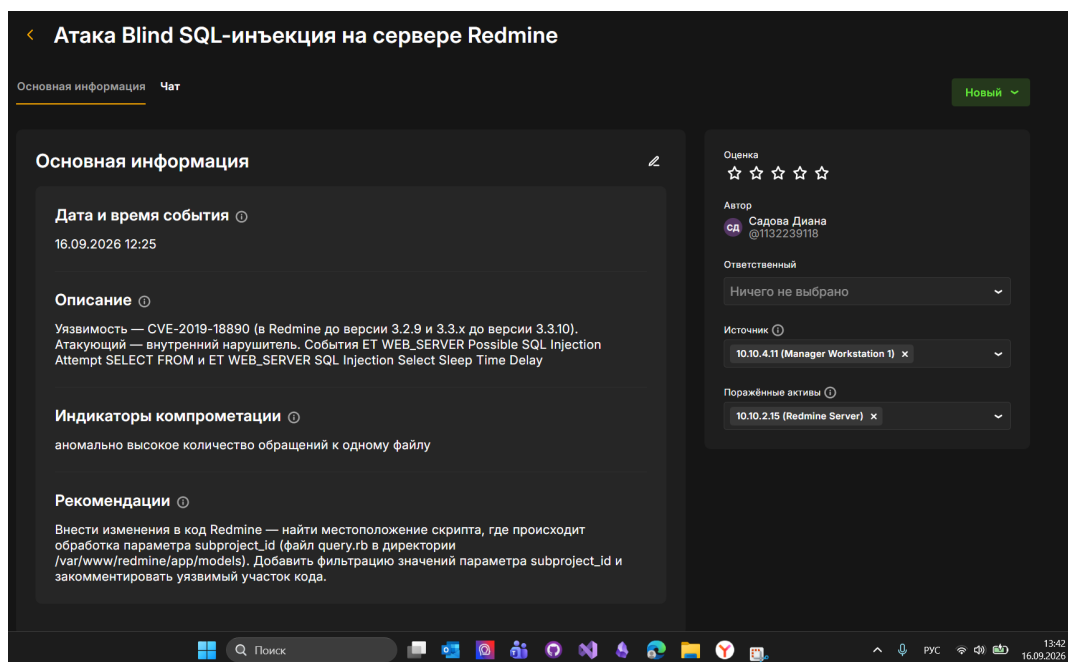


Рис. 3.10: Карточка инцидента «Атака Blind SQL-инъекция на сервере Redmine»

4 Вывод

По результатам анализа событий ViPNet IDS NS и регистрации инцидентов подтверждён факт многоэтапной атаки на инфраструктуру Ampire, соответствующей описанию Сценария №5, а также зафиксированы конкретные рекомендации по устранению каждой из выявленных уязвимостей.